# Hito 2

Minimización, seudonimización y control de acceso en NortiShop

Asignatura: Seguridad y Protección de Datos

Grupo: _____

Integrantes: Ariel Van Kilsdonk y Carlos Orellana

Caso: Plataforma de comercio electrónico NortiShop

Fecha: 29 de octubre de 2026

# Índice

**1 Introducción** ..... 2
**2 Esquema de base de datos y minimización** ..... 2
2.1 Esquema original ..... 2
2.2 Esquema rediseñado ..... 3
2.3 Tabla de decisiones por campo ..... 4
2.4 Alternativas de reducción y aporte a la privacidad ..... 5
**3 Seudonimización y anonimización** ..... 6
3.1 Conceptos aplicados ..... 6
3.2 Dónde se aplica cada técnica ..... 6
3.3 Restricciones sobre la información que revierte seudónimos ..... 7
3.4 Registros, reportes, pruebas y desarrollo ..... 7
**4 Modelo de control de acceso basado en roles** ..... 7
4.1 Roles y responsabilidades ..... 7
4.2 Matriz de permisos ..... 8
4.3 Acciones y datos denegados por rol ..... 9
4.4 Control de información sensible y operaciones administrativas ..... 9
**5 Implementación en el código** ..... 9
**6 Evidencias de pruebas** ..... 10
**7 Conclusión técnica** ..... 12
**8 Referencias** ..... 13

*La numeración de páginas comienza después de la portada.*

# 1 Introducción

Este informe documenta el Hito 2 del caso NortiShop, la tienda chilena de tecnología en línea cuyo inventario, flujos y clasificación de datos se definieron en el Hito 1. El objetivo es pasar de la identificación de datos a su protección efectiva: rediseñar la base de datos con criterio de minimización, decidir dónde seudonimizar o anonimizar, definir un modelo RBAC con mínimo privilegio e implementar todo en el código, con pruebas que demuestren que los controles funcionan y que los accesos indebidos se rechazan.

La implementación está en la carpeta `Sistema_NortiShop` del repositorio. Es una aplicación Python con Flask y SQLite que reutiliza y amplía las técnicas de la Actividad 2: AES-256-GCM por campo, índice ciego HMAC-SHA-256, scrypt para contraseñas y tokenización del medio de pago. Todo el trabajo se hizo con datos sintéticos.

El marco normativo es la Ley 19.628, vigente a la fecha de este informe, y la Ley 21.719, que la modifica desde el 1 de diciembre de 2026. Las decisiones se tomaron pensando en cumplir desde el primer día de la nueva ley, en particular los principios de finalidad, proporcionalidad y seguridad y las definiciones de seudonimización y anonimización de su artículo 2.

# 2 Esquema de base de datos y minimización

## 2.1 Esquema original

El enunciado del caso no entrega un modelo de datos, así que el esquema original se reconstruyó a partir del inventario del Hito 1, tal como quedaría si la tienda se construyera sin criterios de privacidad. Se conserva en `esquemas/esquema_original.sql` solo como punto de comparación. La tabla resume sus problemas.

| Tabla original | Campos | Problemas detectados |
|---|---|---|
| usuarios | nombre, apellidos, rut, email, telefono, telefono_secundario, fecha_nacimiento, genero, password, rol, acepta_marketing, ultima_ip | RUT obligatorio para todos y en claro; fecha de nacimiento y género innecesarios; contraseña MD5 sin sal; clientes y personal en la misma tabla; marketing premarcado y sin versión; IP completa sin plazo. |
| direcciones | calle, numero, depto, comuna, region, latitud, longitud, referencia | Domicilio en claro; geolocalización precisa del domicilio; texto libre sin control. |
| tarjetas | numero_tarjeta, vencimiento, cvv, titular | PAN, vencimiento y CVV en la base del comercio (contrario a PCI DSS). |
| pedidos | destinatario, teléfono, dirección, rut_facturacion, codigo_autorizacion, tarjeta_id | Copias en claro sin plazo; RUT pedido también para boleta; código de autorización legible. |
| despachos | gps_entrega_lat/lon, foto_entrega, firma_receptor | Coordenada exacta, foto y firma: datos que no se necesitan para entregar. |
| nortipuntos | saldo | Saldo editable sin historial ni control de integridad. |
| resenas | nombre_publico | Nombre real publicado. |
| tickets_soporte | mensaje, adjunto | Texto libre en claro que puede contener tarjetas; adjuntos con copias de cédula. |
| eventos_navegacion | usuario_id, email, ip, user_agent, url, fecha_hora | Perfil de navegación identificado, sin consentimiento ni plazo. |

| Tabla original | Campos | Problemas detectados |
|---|---|---|
| logs | usuario (correo), detalle (request completo) | Correos y contraseñas en los registros técnicos. |

*Tabla 1. Esquema original y problemas de privacidad.*

## 2.2 Esquema rediseñado

El esquema rediseñado está en `nortishop/schema.sql` (copia en `esquemas/esquema_redisenado.sql`). Sigue cuatro convenciones: los campos `*_enc` se cifran con AES-256-GCM usando el campo como contexto autenticado; los `*_idx` son índices ciegos para buscar sin descifrar; cada entidad expuesta tiene un `public_id` opaco (UUID), de modo que el id interno nunca sale del sistema; y las restricciones CHECK cierran los valores posibles de estados y roles.

| Tabla | Propósito | Datos personales y protección |
|---|---|---|
| customers | Cuenta del cliente | Nombre, correo y teléfono (opcional) cifrados; índice ciego del correo; `adult_declared` reemplaza la fecha de nacimiento; estado y fecha de supresión. |
| credentials | Autenticación | Hash scrypt (N=2^17, r=8, p=1); intentos fallidos y bloqueo temporal. |
| staff_users | Cuentas del personal | Separadas de los clientes; rol restringido a 8 valores. |
| sessions | Sesiones | Solo el SHA-256 del token; expiración y revocación. |
| addresses | Libreta de direcciones | Calle cifrada; comuna y región en claro (tarifas y reportes). Solo si el cliente decide guardarla. |
| billing_profiles | Datos de factura | RUT, razón social y dirección cifrados; existe solo si se pide factura; `blocked` para conservación legal. |
| orders, order_items | Pedidos | Destinatario, teléfono y calle cifrados con contexto por pedido; `retention_until` de respaldo tributario. |
| payments | Pagos | Marca, últimos 4 y código de autorización cifrado. Sin PAN, CVV ni vencimiento. |
| saved_payment_methods | Medio guardado | Token de pasarela cifrado; solo con consentimiento. |
| shipments | Despachos | Seguimiento y estado; `access_expires_at` limita cuánto tiempo logística ve los datos. |
| loyalty_ledger | NortiPuntos | Movimientos sellados con HMAC encadenado; el saldo se calcula, no se edita. |
| reviews, support_tickets | Contenido | Alias en vez de nombre; mensaje de soporte cifrado y sin adjuntos. |
| analytics_events | Analítica | Seudónimo `customer_ref`, evento, SKU y día. Sin IP ni correo. |
| pseudonym_vault | Reversión de seudónimos | Tabla de correspondencia, legible solo por el DPO. |
| audit_log y tablas del Hito 3 | Auditoría y cumplimiento | Sin datos personales; inmutables por triggers (detalle en el Hito 3). |

*Tabla 2. Esquema rediseñado (resumen).*

## 2.3 Tabla de decisiones por campo

Cada campo del esquema original recibió una de cuatro decisiones: **mantener** (con la protección que corresponda), **eliminar**, **reducir** (menos detalle o menos casos) u **opcional**. La justificación explica qué necesidad funcional cubre el campo y qué riesgo implicaría conservarlo.

| Tabla y campo | Decisión | Justificación |
|---|---|---|
| usuarios: nombre y apellidos | Mantener, cifrado y unificado | Identifica al comprador y al destinatario. Un solo campo `full_name_enc` evita fragmentos innecesarios; el cifrado protege ante una exportación o un respaldo filtrado. |
| usuarios: rut | Reducir (solo factura) | La boleta no requiere el RUT del comprador. Se pide solo al emitir factura, dentro de `billing_profiles`, cifrado y con índice ciego. Conservar el RUT de todos los clientes aumentaría el impacto de una filtración y facilitaría cruces de bases. |
| usuarios: email | Mantener con protección | Es la credencial de acceso y el canal de confirmaciones. Se guarda cifrado y se busca por índice ciego, sin texto claro. |
| usuarios: telefono | Opcional | La cuenta funciona sin teléfono. El checkout pide un teléfono de contacto del despacho, que se guarda en el pedido y no en el perfil. |
| usuarios: telefono_secundario | Eliminar | No es indispensable si basta un medio de contacto; duplicaba la exposición. |
| usuarios: fecha_nacimiento | Eliminar | Solo se necesita saber que el comprador es mayor de edad. Se guarda el resultado de la declaración (`adult_declared`); la fecha completa sería un identificador adicional sin uso. |
| usuarios: genero | Eliminar | No interviene en vender, cobrar ni despachar. Usarlo para segmentar sería otra finalidad que requeriría consentimiento. |
| usuarios: password (MD5) | Mantener con protección adecuada | Es necesaria para autenticar, pero MD5 sin sal se revierte con tablas precalculadas. Pasa a scrypt con sal única, verificación en tiempo constante y bloqueo tras 5 intentos fallidos. |
| usuarios: rol | Separar | El personal pasa a `staff_users` con roles cerrados. Mezclarlos permitía escalar privilegios editando una columna del cliente. |
| usuarios: acepta_marketing | Eliminar (reemplazo) | Un booleano premarcado no prueba un consentimiento libre ni informado. Se reemplaza por eventos de consentimiento por finalidad, con versión del texto (Hito 3). |
| usuarios: ultima_ip | Eliminar | La IP completa permite rastrear al usuario. Solo la auditoría guarda la red truncada (/24) con un plazo definido. |
| direcciones: calle, número, depto | Mantener, cifrado | Necesarios para entregar. Se unen en `street_enc` cifrado. |
| direcciones: comuna y región | Mantener en claro | Calculan la tarifa de despacho y permiten reportes agregados. Por sí solas no identifican a nadie. |
| direcciones: latitud y longitud | Eliminar | La geolocalización es una categoría especial según el Hito 1 y no es necesaria: la dirección basta para despachar. |
| direcciones: referencia libre | Reducir | Se elimina el campo libre. Las indicaciones breves caben en la dirección (máximo 120 caracteres). |
| direcciones (libreta) | Opcional | Solo se guardan si el cliente marca «guardar dirección». Si no, la dirección vive únicamente en el pedido. |
| tarjetas: numero_tarjeta | Eliminar | El PAN se ingresa en la pasarela. NortiShop recibe el token, la marca y los últimos 4 dígitos. |
| tarjetas: vencimiento, cvv, titular | Eliminar | PCI DSS prohíbe almacenar el CVV después de autorizar. Vencimiento y titular los gestiona la pasarela. |

| Tabla y campo | Decisión | Justificación |
|---|---|---|
| tarjetas (medio guardado) | Opcional | El token de la pasarela se conserva cifrado solo con el consentimiento «guardar medio de pago». |
| pedidos: destinatario, teléfono, dirección | Mantener cifrado; reducir en el tiempo | Se necesitan para entregar. Se cifran con contexto por pedido y se borran al suprimir la cuenta; luego de la entrega, logística deja de verlos. |
| pedidos: rut_facturacion | Reducir | Se reemplaza por `billing_profile_id`, que existe solo si se pidió factura. |
| pedidos: codigo_autorizacion | Mantener cifrado | Sirve para conciliar y resolver disputas. Se cifra y no se muestra a soporte. |
| pedidos: total, fecha, ítems | Mantener | Respaldo comercial y tributario. Se agrega `retention_until` (6 años propuestos, por validar con asesoría legal). |
| despachos: gps, foto, firma | Eliminar | Basta registrar el estado y la fecha de entrega. Coordenadas, foto y firma exponen al destinatario y su domicilio sin necesidad. |
| nortipuntos: saldo | Reemplazar | Un saldo editable no detecta fraudes. Se guarda un libro de movimientos sellado con HMAC y el saldo se calcula. |
| resenas: nombre_publico | Reducir | Se publica un alias elegido por el cliente. El texto se valida para que no incluya correo, RUT ni tarjeta. |
| tickets: mensaje | Mantener cifrado | Es necesario para atender. Se cifra y se rechaza si contiene un número de tarjeta válido. |
| tickets: adjunto | Eliminar | Las copias de cédula o comprobantes no son necesarias para la verificación proporcional definida en el Hito 3. |
| eventos_navegacion | Seudonimizar y reducir | Pasa a `analytics_events`: seudónimo, evento, SKU y solo el día; sin IP, correo ni user agent; solo con consentimiento de analítica; 13 meses. |
| logs: usuario y detalle | Reemplazar | Se separan en auditoría saneada (sin datos personales) y logs técnicos con redacción automática. |

*Tabla 3. Decisiones por campo.*

## 2.4 Alternativas de reducción y aporte a la privacidad

Donde un dato no se pudo eliminar, se buscó una versión con menos detalle o menos exposición:

- **Resultado en vez de dato:** declaración de mayoría de edad en lugar de fecha de nacimiento; indicador `blocked` en lugar de mantener activo un perfil de factura.
- **Generalización:** comuna y región en claro en vez de la dirección; día en vez de fecha y hora en analítica; tramos de monto en reportes.
- **Sustitución:** token de pasarela en vez de PAN; alias en vez de nombre; seudónimo en vez de id en analítica y marketing.
- **Limitación temporal:** la ventana `access_expires_at` limita lo que ve logística; los datos de contacto del pedido se eliminan al suprimir la cuenta; cada tabla tiene un plazo de conservación.
- **Opcionalidad real:** teléfono, libreta de direcciones y medio de pago guardado solo existen si el cliente los entrega o los autoriza.

El nuevo diseño contribuye a la minimización de tres maneras. Primero, el sistema **no puede** almacenar lo que ya no tiene columna: el validador de cada operación rechaza campos desconocidos y prohibidos con un mensaje explícito. Segundo, lo que se conserva queda cifrado por campo, así que una copia de la base, un respaldo o una exportación no revelan datos sin las llaves, que viven fuera de la base. Tercero, la cantidad de

personas que ven datos completos baja a quienes los necesitan en cada momento: el titular, logística durante el despacho y el proceso del DPO.

# 3 Seudonimización y anonimización

## 3.1 Conceptos aplicados

Se usan las definiciones de la Ley 21.719 (artículo 2, letras k y l). La **seudonimización** reemplaza identificadores directos por códigos, de modo que el dato ya no se puede atribuir a una persona **sin información adicional**, que se guarda por separado y protegida; el dato sigue siendo personal. La **anonimización** es irreversible: se destruye el nexo con la persona, considerando también la posibilidad de cruzar con otras fuentes, y el resultado deja de ser dato personal.

En NortiShop un seudónimo se calcula como `ps_` + HMAC-SHA-256(llave de seudonimización, dominio ‖ id interno), truncado a 20 caracteres hexadecimales. Cada dominio (consentimiento, analítica, marketing) produce seudónimos distintos para la misma persona, de modo que dos conjuntos no se pueden enlazar entre sí. La información adicional es doble: la llave, fuera de la base, y la tabla `pseudonym_vault`.

## 3.2 Dónde se aplica cada técnica

| Módulo o proceso | Técnica | Implementación | Qué protege y por qué es adecuada |
|---|---|---|---|
| Analítica de navegación (`analytics_events`) | Seudonimización | `customer_ref` de dominio analítica; solo día; registro condicionado al consentimiento. | Hábitos de navegación. Se necesita agrupar por persona (embudos, recurrencia) sin saber quién es; anonimizar impediría esas métricas. |
| Audiencia de marketing | Seudonimización | El endpoint entrega seudónimos de dominio marketing de quienes tienen consentimiento vigente; el proveedor resuelve con su propia lista de suscripción. | Identidad y correo frente al equipo de marketing, que no necesita saber quién es cada destinatario. |
| Evidencia de consentimiento (`consent_events`) | Seudonimización | `subject_ref` de dominio consentimiento; al suprimir la cuenta se borra la correspondencia. | Permite probar una revocación sin conservar la identidad después de la supresión. |
| Auditoría | Seudonimización | Actores y recursos por `public_id` (UUID) o seudónimo; IP truncada a /24. | Permite investigar incidentes sin copiar nombres ni correos en los registros. |
| Vistas de soporte y finanzas | Enmascaramiento | Nombre «Camila R. G.», correo «c*@dominio», teléfono «+5691234», tarjeta «VISA **1111». | Soporte confirma que habla con el titular sin ver el dato completo. |
| Reporte de ventas | Anonimización | Agregación por región y mes, montos en tramos y supresión de celdas con menos de 5 clientes distintos (k = 5). | Finanzas y gerencia no necesitan individuos; el umbral k evita reidentificar a quien compra en una región pequeña. |
| Métricas de campañas | Anonimización | Conteos por evento y SKU publicados solo si involucran 5 o más personas. | Evita deducir el comportamiento de una persona desde una métrica pequeña. |
| Dataset de desarrollo y pruebas | Anonimización | Sin identificadores; cliente reemplazado por un correlativo cuya correspondencia se descarta; mes, región y tramo. | Los ambientes de desarrollo nunca reciben datos reales. |
| Titular suprimido | Anonimización por destrucción del nexo | Se borran las filas de `pseudonym_vault` del titular; los eventos seudonimizados restantes ya no se pueden vincular. | Cumple la supresión sin romper estadísticas agregadas. |

*Tabla 4. Aplicación de seudonimización y anonimización.*

Un ejemplo de la ejecución real: el evento de analítica guardado es `{"customer_ref":"ps_a4af2e697a68d4fab8dd","event":"vista_producto","sku":"SSD-1TB","occurred_on":"2026-10-30"}`, y la audiencia de marketing contiene solo seudónimos (ps_942b2d29202237b3fbef). El seudónimo de marketing y el de analítica de la misma persona son distintos.

### 3.3 Restricciones sobre la información que revierte seudónimos

- **Solo el DPO revierte.** El permiso `seudonimos:revertir` existe únicamente en su rol, y el authorizer de SQLite rechaza cualquier lectura de `pseudonym_vault` desde otra conexión. En la evidencia, marketing obtuvo HTTP 403 al intentarlo y el DPO HTTP 200.
- **Motivo obligatorio y auditado.** La reversión exige un motivo de al menos 10 caracteres y genera el evento `seudonimo.reversion`.
- **Llave separada de los datos.** La llave de seudonimización viene del gestor de secretos y no se guarda en la base ni en el repositorio. Sin ella no se pueden recalcular seudónimos, aunque se robe la tabla.
- **Ninguna vista combina seudónimo e identidad.** Ningún endpoint del personal devuelve ambos a la vez.

### 3.4 Registros, reportes, pruebas y desarrollo

- **Registros técnicos:** `RedactingFilter` enmascara correos, RUT, teléfonos, números de tarjeta y tokens Bearer en todos los loggers de la aplicación. Las trazas de excepción se reemplazan por el tipo de error y un `request_id`.
- **Respuestas de error:** el cliente recibe solo `{"error": "error_interno", "request_id": ...}`, nunca la traza ni valores.
- **Auditoría:** `sanitize()` descarta claves como password, token, codigo o key y enmascara valores con forma de dato personal antes de guardar.
- **Reportes:** solo agregados k-anónimos; no existe un endpoint de exportación masiva de clientes.
- **Pruebas y desarrollo:** las pruebas generan personas sintéticas (`nortishop/seed.py`) y llaves efímeras en memoria. Para analizar datos de producción se usa el dataset anonimizado. Copiar la base real a desarrollo está prohibido por procedimiento.

## 4 Modelo de control de acceso basado en roles

### 4.1 Roles y responsabilidades

| Rol | Responsabilidad |
|---|---|
| Cliente | Titular de los datos. Gestiona su cuenta, pedidos, consentimientos y solicitudes de derechos. |
| Soporte | Atiende tickets y consultas; ve datos de clientes enmascarados. |
| Logística | Coordina despachos activos; ve destinatario, contacto y dirección solo durante la ventana de entrega. |
| Marketing | Gestiona campañas con audiencias seudonimizadas y métricas agregadas. |

| Rol | Responsabilidad |
|---|---|
| Finanzas | Concilia pagos enmascarados y usa reportes anonimizados. |
| Administrador | Administra catálogo, estados de pedidos y cuentas del personal no protegidas. No ve datos personales completos. |
| DPO (encargado de protección de datos) | Procesa solicitudes de derechos, prorroga plazos, consulta consentimientos y es el único que revierte seudónimos. |
| Oficial de seguridad | Gestiona alertas e incidentes y ejecuta la contención y la recuperación. |
| Auditor | Revisa y verifica el registro de auditoría en modo de solo lectura. |

*Tabla 5. Roles del sistema.*

## 4.2 Matriz de permisos

La matriz usa estas abreviaturas: **Cl** cliente, **So** soporte, **Lo** logística, **Mk** marketing, **Fi** finanzas, **Ad** administrador, **DPO**, **Se** oficial de seguridad y **Au** auditor. «Enm.» significa que el dato se ve enmascarado.

| Acción o recurso | Cl | So | Lo | Mk | Fi | Ad | DPO | Se | Au |
|---|---|---|---|---|---|---|---|---|---|
| Gestionar roles y permisos | No | No | No | No | No | Sí, salvo roles protegidos y el propio | No | No | No |
| Consultar datos propios | Sí | – | – | – | – | – | – | – | – |
| Consultar datos de otros usuarios | No | Enm. | Despachos activos | No | No | Enm. | Enm.; completo solo en solicitudes | No | No |
| Modificar información sensible | Solo la propia, vía rectificación | No | Estado del despacho | No | No | Estado del pedido | Ejecuta solicitudes | Cuentas (contención) | No |
| Audiencia de campañas | No | No | No | Seudónimos con consenti-miento | No | No | No | No | No |
| Pagos y reportes de ventas | Propios | No | No | No | Enm. y anonimizado | No | No | No | No |
| Revertir seudónimos | No | No | No | No | No | No | Sí, con motivo | No | No |
| Consultar auditoría | No | No | No | No | No | No | Sí | Sí | Sí |
| Modificar o borrar auditoría | No | No | No | No | No | No | No | No | No |
| Contención y recuperación | No | No | No | No | No | No | No | Sí | No |
| Acceder a claves criptográficas | No | No | No | No | No | No | No | No | No |

*Tabla 6. Matriz de permisos. Las claves solo las usa el proceso de la aplicación mediante el gestor de secretos o KMS; ningún rol humano accede a ellas.*

### 4.3 Acciones y datos denegados por rol

| Rol | No debe estar disponible |
|---|---|
| Cliente | Datos de otros clientes, auditoría, seudónimos, funciones administrativas. |
| Soporte | RUT, dirección y teléfono completos; tokens y códigos de pago; exportaciones masivas; ejecutar supresiones; auditoría. |
| Logística | Pedidos entregados o fuera de la ventana; RUT, correo, historial y pagos; clientes sin despacho. |
| Marketing | Nombre, correo y RUT reales; revertir seudónimos; clientes sin consentimiento; historial individual de compras. |
| Finanzas | Token de pago y PAN; datos de contacto; registros individuales en reportes. |
| Administrador | Descifrar datos personales completos; modificar o borrar auditoría; llaves; cambiar su propio rol; asignar roles DPO, seguridad o auditor. |
| DPO | Modificar o borrar auditoría; llaves; cambiar roles. |
| Oficial de seguridad | Datos personales de clientes; revertir seudónimos; modificar auditoría. |
| Auditor | Cualquier escritura; datos personales de clientes. |

*Tabla 7. Denegaciones explícitas (constante EXPLICIT_DENIALS en nortishop/rbac.py).*

### 4.4 Control de información sensible y operaciones administrativas

El control de acceso se aplica en dos capas independientes, ambas en el servidor:

1. **Capa de aplicación.** Cada endpoint declara su permiso con `@require("permiso")`. El rol sale de la sesión guardada en la base (el token se compara por su hash), nunca de un dato enviado por el cliente. Sin sesión se responde 401 y sin permiso 403, ambos auditados y evaluados por el detector de accesos denegados reiterados.
2. **Capa de datos.** Cada solicitud abre una conexión SQLite con un *authorizer* construido desde `DB_POLICY`, que lista las tablas que el rol puede leer y escribir (para marketing y seguridad, incluso las columnas de `customers`). Si un endpoint tuviera un error de lógica, la consulta a una tabla no autorizada igual falla en el motor.

Para las operaciones sensibles y administrativas se suman estas reglas: roles protegidos (administrador, DPO, seguridad, auditor) que el administrador no puede asignar y que requieren un proceso fuera de banda con dos aprobaciones; prohibición de modificar el propio rol; revocación inmediata de las sesiones del afectado cuando cambia su rol; sesiones de 30 minutos para el personal y 120 para clientes; bloqueo tras 5 intentos fallidos; respuestas genéricas que no revelan si una cuenta existe; y tablas de evidencia (auditoría, consentimientos, seudónimos) que solo escriben servicios internos que sellan cada registro.

## 5 Implementación en el código

| Requisito de la pauta | Implementación | Funcionamiento |
|---|---|---|
| Impedir datos innecesarios | `validation.py`: `validate()`, `FORBIDDEN_FIELDS`, especificaciones por operación | Lista blanca por endpoint; campos prohibidos con mensaje; RUT con dígito verificador; teléfono normalizado; rechazo de PAN válido por Luhn en texto libre; reseñas sin correo ni RUT. |
| Protección de campos sensibles | `crypto.py`: `FieldProtector`, `Keyring` | AES-256-GCM con nonce aleatorio y contexto por campo; prefijo de versión de llave para rotar; índice ciego para correo y RUT. |

| Requisito de la pauta | Implementación | Funcionamiento |
|---|---|---|
| Contraseñas y claves | `PasswordHasher`; `Keyring.from_environment`; `.env.example`; `cli.py rotate-keys` | scrypt N=2^17 con sal; llaves de 32 bytes desde variables de entorno o KMS; `rotate-keys` recifra toda la base; `.env` excluido del repositorio. |
| Seudonimización y anonimización | `crypto.Pseudonymizer`, `privacy.py` | Seudónimos HMAC por dominio; tabla de reversión restringida; reporte k-anónimo; dataset para desarrollo. |
| Autenticación y autorización | `api.py`: `load_actor`, `require`, `_login` | Tokens aleatorios con hash en la base, expiración, revocación y bloqueo; permisos por rol. |
| Restricciones en la base de datos | `db.py`: `RoleAuthorizer`, `connect_for_role`; triggers en `schema.sql` | Política por tabla y columna; bloquea ATTACH y PRAGMA; auditoría y consentimiento inmutables incluso para la conexión de sistema. |
| Errores y registros seguros | `logging_utils.py`, `register_handlers`, `audit.sanitize` | Redacción de datos personales en logs; respuestas genéricas con request_id; auditoría saneada. |
| Pruebas | `tests/test_hito2_minimizacion_rbac.py` (18 pruebas) | Casos permitidos y denegados para cada control. |

*Tabla 8. Trazabilidad entre la pauta y el código.*

Fragmento del decorador que aplica el permiso en el servidor:

```
def require(permission: str):
    def decorator(fn):
        @functools.wraps(fn)
        def wrapper(*args, **kwargs):
            if g.actor["type"] == "anonimo":
                return deny(401, "sin_sesion", permission)
            if not rbac.has_permission(g.actor["role"], permission):
                return deny(403, "rol_sin_permiso", permission)
            return fn(*args, **kwargs)
```

Fragmento del authorizer que restringe la conexión SQL de cada rol:

```
if action == sqlite3.SQLITE_READ:
    table = VIEW_SOURCES.get(arg1, arg1)
    if table not in self.readable:
        return sqlite3.SQLITE_DENY
    if table == "customers" and self.role in CUSTOMER_STATUS_ROLES \
            and column not in CUSTOMER_STATUS_COLUMNS:
        return sqlite3.SQLITE_DENY
```

# 6 Evidencias de pruebas

La suite completa (Hitos 2 y 3) ejecuta 47 pruebas, todas aprobadas; el detalle está en `evidencias/resultado_pruebas.txt`. Las 18 pruebas del Hito 2 son las siguientes.

| Prueba | Qué demuestra | Resultado |
|---|---|---|
| registration_rejects_fields_removed_by_redesign | Fecha de nacimiento, género y teléfono secundario se rechazan y no se crea la cuenta | OK |
| phone_is_optional_and_minor_accounts_are_rejected | La cuenta funciona sin teléfono; sin declaración de mayoría de edad no hay cuenta | OK |

| Prueba | Qué demuestra | Resultado |
|---|---|---|
| checkout_rejects_card_data_and_free_text_with_pan | CVV, PAN y latitud se rechazan; un ticket con tarjeta y una reseña con correo también | OK |
| rut_only_collected_for_invoices | Una boleta no genera perfil de factura; una factura sí | OK |
| personal_data_is_never_stored_in_plaintext | El volcado completo de la base no contiene nombre, correo, teléfono, calle, RUT, contraseña, token ni código | OK |
| key_rotation_reencrypts_without_losing_data | Un campo v1 se recifra con v2 y se recupera | OK |
| permission_matrix_is_enforced_by_server | 9 endpoints × 10 actores: 200, 401 o 403 según la matriz | OK |
| forged_or_revoked_tokens_are_rejected | Tokens inventados o cerrados reciben 401 | OK |
| support_sees_only_masked_data | La respuesta de soporte no contiene correo, teléfono ni nombre completos | OK |
| logistics_window_closes_after_delivery | Tras la entrega, logística deja de ver el despacho | OK |
| admin_cannot_escalate_privileges | No cambia su propio rol ni asigna roles protegidos; el cambio permitido revoca sesiones | OK |
| database_layer_blocks_unauthorized_tables | 12 consultas indebidas rechazadas por el motor para 7 roles | OK |
| audit_table_is_immutable_even_for_system_connection | UPDATE y DELETE sobre la auditoría fallan por trigger | OK |
| analytics_and_marketing_use_pseudonyms | Analítica y marketing usan seudónimos distintos; solo el DPO revierte y queda auditado | OK |
| sales_report_is_k_anonymous | Una región con 2 clientes se suprime; una con 5 se publica | OK |
| dev_dataset_contains_no_identifiers | El dataset de desarrollo tiene solo 5 columnas generalizadas | OK |
| internal_errors_do_not_leak_details_and_logs_are_redacted | Un error 500 no expone la traza; el log no contiene correo ni tarjeta | OK |
| login_lockout_and_no_user_enumeration | Misma respuesta para cuenta inexistente o clave errónea; bloqueo y alerta tras 5 intentos | OK |

*Tabla 9. Pruebas del Hito 2.*

## Resultado HTTP real obtenido por cada actor (generado por `scripts/generar_evidencias.py`):

| Endpoint | Anón. | So | Lo | Mk | Fi | Ad | DPO | Se | Au | Cl |
|---|---|---|---|---|---|---|---|---|---|---|
| /api/me | 401 | 403 | 403 | 403 | 403 | 403 | 403 | 403 | 403 | 200 |
| /api/personal/clientes | 401 | 200 | 403 | 403 | 403 | 200 | 200 | 403 | 403 | 403 |
| /api/logistica/despachos | 401 | 403 | 200 | 403 | 403 | 403 | 403 | 403 | 403 | 403 |
| /api/marketing/audiencia | 401 | 403 | 403 | 200 | 403 | 403 | 403 | 403 | 403 | 403 |
| /api/finanzas/pagos | 401 | 403 | 403 | 403 | 200 | 403 | 403 | 403 | 403 | 403 |
| /api/reportes/ventas | 401 | 403 | 403 | 403 | 200 | 403 | 403 | 403 | 403 | 403 |
| /api/dpo/solicitudes | 401 | 403 | 403 | 403 | 403 | 403 | 200 | 403 | 403 | 403 |
| /api/auditoria | 401 | 403 | 403 | 403 | 403 | 403 | 200 | 200 | 200 | 403 |
| /api/seguridad/alertas | 401 | 403 | 403 | 403 | 403 | 403 | 403 | 200 | 403 | 403 |

*Tabla 10. Matriz RBAC ejecutada (200 permitido, 401 sin sesión, 403 denegado).*

| Rol | Consulta directa | Resultado |
|---|---|---|
| soporte | SELECT password_hash FROM credentials | RECHAZADO por el motor: access to credentials.password_hash is prohibited |

| Rol | Consulta directa | Resultado |
|---|---|---|
| soporte | SELECT * FROM pseudonym_vault | RECHAZADO por el motor: access to pseudonym_vault.pseudonym is prohibited |
| marketing | SELECT full_name_enc FROM customers | RECHAZADO por el motor: access to customers.full_name_enc is prohibited |
| logistica | SELECT email_enc FROM customers | RECHAZADO por el motor: access to customers.email_enc is prohibited |
| finanzas | SELECT gateway_token_enc FROM saved_payment_methods | RECHAZADO por el motor: access to saved_payment_methods.gateway_token_enc is prohibited |
| administrador | SELECT * FROM audit_log | RECHAZADO por el motor: access to audit_log.id is prohibited |
| auditor | DELETE FROM audit_log | RECHAZADO por el motor: not authorized |
| cliente | UPDATE consent_events SET action='otorgado' | RECHAZADO por el motor: not authorized |

*Tabla 11. Rechazos del authorizer de SQLite ante consultas directas.*

Así queda una fila de `customers` en la base (valores truncados):

```
public_id       0a64d711-50d9-4eb1-aec9-50d4ab06045a
full_name_enc   v1:4TUvliiR_WfBejF3KaeioVYqYEoHtzRNh8OWegHKoJuxX…
email_enc       v1:NjDsUJJnPc_ejvbcSlq89WvS5Bj9TYhGO5xFySKvdVteD…
email_idx       uKGRKbbvSkHlGog1hSwN0607inJ22RobHEkbzrzz8Gk
phone_enc       v1:s0jCut9ioyWMmPlx6-IU5oLDEK0CJ9Iyu5MVsDX2STifT…
adult_declared  1
status          active
```

La contraseña se guarda con el formato `scrypt$131072$8$1$<sal>$<hash>`. Un registro con fecha de nacimiento y género recibió HTTP 400 con el motivo de minimización de cada campo, y un checkout con CVV recibió HTTP 400.

# 7 Conclusión técnica

**Mejoras alcanzadas.** El rediseño elimina más de una docena de campos sin finalidad (fecha de nacimiento, género, teléfono secundario, coordenadas, PAN, CVV, vencimiento, foto y firma de entrega, entre otros), restringe el RUT a la factura y cifra todos los identificadores, contactos y ubicaciones que se conservan. Analítica, marketing, consentimientos y auditoría trabajan con seudónimos, y lo que sale hacia reportes o desarrollo se anonimiza con un umbral explícito. El RBAC aplica mínimo privilegio en dos capas y las pruebas demuestran tanto los accesos permitidos como los rechazados.

**Limitaciones.** SQLite no tiene usuarios ni seguridad por fila: el authorizer protege la conexión de la aplicación, pero no a quien obtenga el archivo de la base. Esto se mitiga con cifrado por campo y triggers, y en producción se resolvería con PostgreSQL, roles con GRANT y Row Level Security. Las llaves llegan por variables de entorno en lugar de un KMS. El umbral k = 5 es simple y no protege contra todos los ataques de inferencia. Además, el filtro de un cliente sobre sus propios registros vive en la aplicación, no en el motor.

**Riesgos por mitigar.** Falta un segundo factor para el personal. Hay que validar legalmente los plazos de conservación tributaria. Faltan contratos con el proveedor de mailing y la pasarela que respalden la seudonimización. Los respaldos deben cifrarse y la rotación de llaves debe automatizarse. También conviene monitorear la reidentificación cuando se crucen reportes agregados con fuentes externas.

# 8 Referencias


1. Biblioteca del Congreso Nacional. Ley 19.628 sobre protección de la vida privada (versión vigente hasta el 30-11-2026). Arts. 2, 4, 9 y 11.
2. Biblioteca del Congreso Nacional. Ley 21.719 que regula la protección y el tratamiento de los datos personales. Art. 2 letras g, k y l (dato sensible, anonimización, seudonimización); art. 3 (principios); art. 14 quinquies (seguridad). https://www.bcn.cl/leychile/navegar?idNorma=1209272
3. OWASP. Password Storage Cheat Sheet (parámetros mínimos de scrypt).
4. NIST SP 800-38D. Galois/Counter Mode (GCM) and GMAC.
5. NIST SP 800-162 y ANSI INCITS 359. Modelos de control de acceso y RBAC.
6. PCI Security Standards Council. PCI DSS v4.0, requisito 3.3 (no almacenar datos sensibles de autenticación) y Tokenization Guidelines.
7. Sweeney, L. (2002). k-anonymity: a model for protecting privacy. International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems.
8. Material del curso: Seguridad y Protección de Datos, PR-01 y PR-02; Informe Hito 1 NortiShop; Actividades 1 y 2.